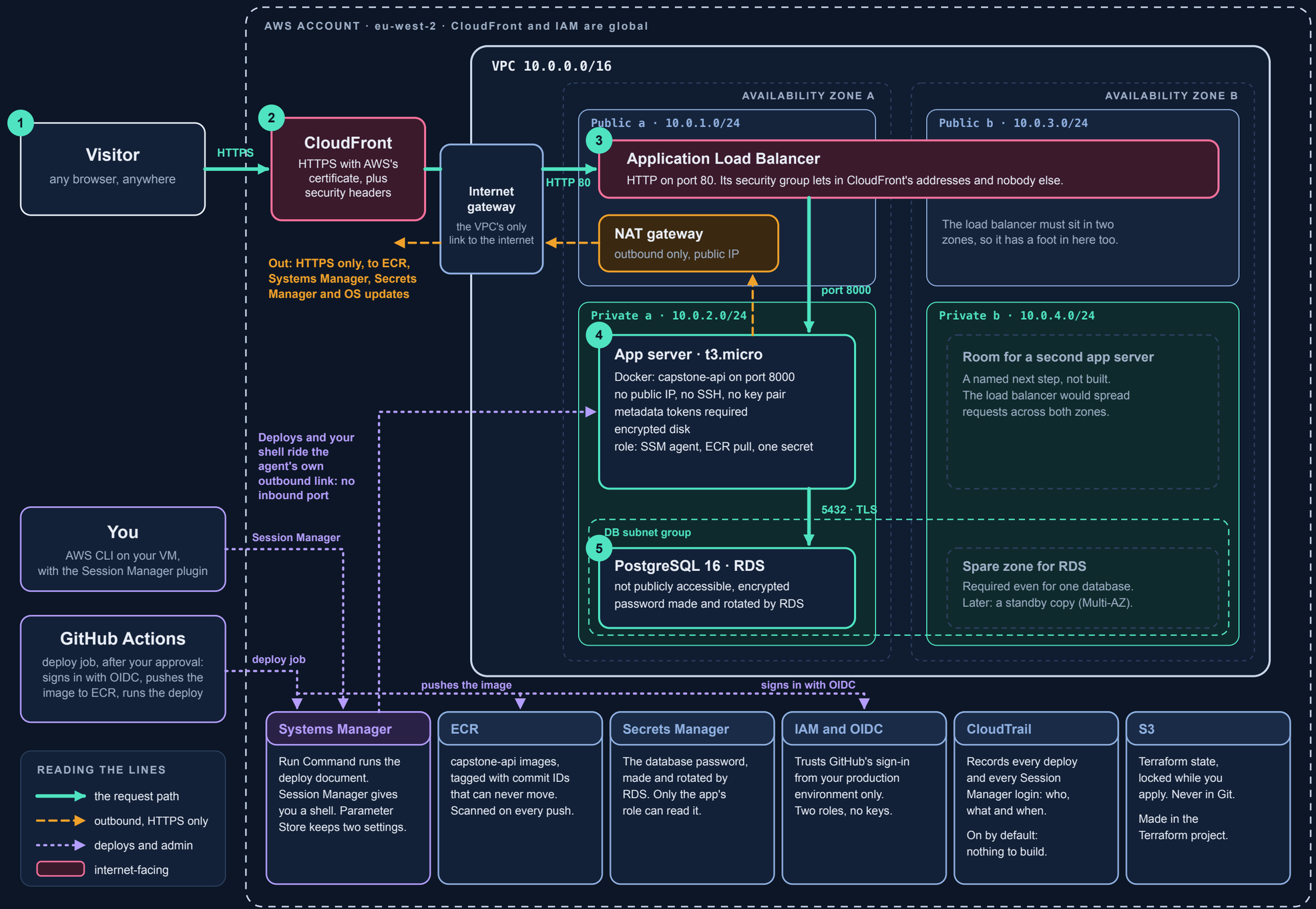
Capstone architecture

One request from a visitor to the database, and every other way in or out. Tech Two Forty · eu-west-2 (London)

IN ONE SENTENCE

Visitors reach CloudFront over HTTPS. Only CloudFront can reach the load balancer, only the load balancer can reach the app, and only the app can reach the database. Nothing has a way in that is not on this page.



You

AWS CLI on your VM, with the Session Manager plugin

GitHub Actions

deploy job, after your approval: signs in with OIDC, pushes the image to ECR, runs the deploy

READING THE LINES

- the request path
- outbound, HTTPS only
- deploys and admin
- internet-facing

TRACE ONE REQUEST

1. A browser asks CloudFront for the page, over HTTPS.
2. CloudFront passes it to the load balancer on port 80.
3. The load balancer sends it to the app server on port 8000, while /health is passing.
4. The app reads the database password from Secrets Manager, using its IAM role.
5. It queries PostgreSQL on 5432 over TLS, and the page goes back the same way.

SECURITY GROUP CHAIN

CloudFront's address list
↓ 80
capstone-alb
↓ 8000
capstone-app
↓ 5432
capstone-db

Inside the VPC, rules name the next group, never an IP address. The app may send HTTPS out, nothing else. The VPC's default group is emptied.

No rule anywhere opens port 22.

TWO IDENTITIES, NO KEYS

capstone-app · the server
Systems Manager agent, pull from ECR, read the one database secret

capstone-deploy · the pipeline
Assumable only from your repo's production environment. Push to one repository, run one document on one server, read two settings.

WHAT IS DELIBERATELY MISSING

No bastion and no SSH, anywhere.
No public IP on the server or the database.
No password in code, Git, an image or state.
No AWS access key in GitHub.
No image tag that can be moved.
No deploy without a person saying yes.